DFIR TECHNICAL REPORT

Post-Mortem Analysis of Compromised WordPress Web Server

CONFIDENTIAL // DFIR

AUTHOR	ROLE	DATE	LAB / PLATFORM
Jonathan Di Genova	Junior SOC Analyst	Nov 2026	WordpressWebForensics (HTB)

1. CASE OVERVIEW & SCOPE

A corporate web server hosting a WordPress installation experienced an unauthorized intrusion resulting in service degradation and persistence establishment. This report details the Digital Forensics and Incident Response (DFIR) investigation conducted using a Splunk SIEM instance ingested with Apache2 access (`access.log.5`) and error (`error.log.5`) logs to profile the threat actor's tactics, techniques, and procedures (TTPs).

> **Primary Objective:** Reconstruct the attack timeline, identify adversary infrastructure, pinpoint the exact compromised entry point, isolate the web shell persistent mechanism, and provide actionable defensive remediation recommendations.

2. KEY EVIDENCE & IDENTIFIED INDICATORS (IOCS)

ARTIFACT TYPE	TECHNICAL VALUE / DESCRIPTION	ATTACKER TTP / CONTEXT
Attacker IP	`203.101.190.116`	Originating IP address for enumeration, brute-force, and shell access.
Target Server IP	`10.129.185.147`	Target server running Apache2, WordPress, and Splunk SIEM.
Recon Tool	`WPScan v3.8.25`	Automated security scanner used for user and theme discovery.
Targeted Theme	`twentytwentyfour`	Active WordPress theme directory abused for persistent backdooring.
Webshell File	`hidden-404.php`	Malicious PHP entry point added inside the theme pattern directory.
Shell User-Agent	`Mozilla/5.0 (... Firefox/129.0)`	Interactive browser User-Agent string used during command execution.

3. CHRONOLOGICAL INVESTIGATION TIMELINE

TIMESTAMP (UTC)	PHASE	EVENT DESCRIPTION & TECHNICAL ANALYSIS
`2024-08-28 03:15:23`	Reconnaissance	Initial automated enumeration detected via `WPScan v3.8.25`, targeting core files and plugin endpoints.
`2024-08-28 03:50:33`	Credential Access	Attacker initiates high-frequency `POST` requests against `/wp-login.php` via automated script.
`2024-08-28 03:50:40`	Credential Access	Brute-force burst concludes after **7 seconds** of continuous automated authentication attempts.
`2024-08-28 03:51:29`	Initial Access	Successful administrative login (`HTTP 302`) achieved and session established via standard browser User-Agent.

TIMESTAMP (UTC)	PHASE	EVENT DESCRIPTION & TECHNICAL ANALYSIS
`2024-08-28 03:57:30`	Persistence	Attacker navigates to the WordPress Theme Editor (`theme-editor.php`) within the active `twentytwentyfour` theme.
`2024-08-28 04:03:51`	Execution / Impact	First remote command execution triggered via `POST` requests to the web shell `hidden-404.php` using parameter `cmd`.

4. DEFENSIVE TAKEAWAYS & HARDENING RECOMMENDATIONS

- **Authentication Protection & MFA:** Implement mandatory Multi-Factor Authentication (MFA) for administrative accounts and configure strict rate-limiting and IP banning rules (e.g., Fail2Ban or WAF policies) on `/wp-login.php`.
- **Disable Dashboard Code Editing:** Restrict inline file modification by adding `define('DISALLOW_FILE_EDIT', true);` to `wp-config.php`, preventing attackers with compromised credentials from altering theme PHP files.
- **File Integrity Monitoring (FIM):** Deploy host-based FIM to monitor critical system directories, specifically `/wp-content/themes/` and `/wp-content/plugins/`, alerting instantly on unauthorized file creations or edits.
- **SIEM Detections: Establish custom correlation rules in Splunk to flag short-duration POST bursts to authentication endpoints paired with immediate downstream theme directory modifications.**